

Gestão de Cibersegurança

Universidade do Minho

2025/2026

Practical Lab Exercises #06

pg60986 — João Afonso Carneiro Araújo e Silva — MCS

pg59797 — Rui Pedro Ramos Carvalho — MCS

pg60307 — Tiago Leal Baganha — MCS

1.

O risco identificado mais relevante foi **ataques ransomware ou fuga de dados na base de dados dos pacientes**.

Step 1 - Estabelecer Critérios de Medição de Risco

Critérios de Medição de Risco – Finanças			
Área de impacto	Alto	Médio	Baixo
Custos operacionais	Aumento superior a 1 000 000 € em despesas (ex.: reconstrução total de sistemas e contratação de especialistas externos).	Aumento entre 100 000 € e 1 000 000 € (ex.: serviços de mitigação e reforço de infraestrutura).	Aumento inferior a 100 000 € (custos administrativos e técnicos menores).
Perda de Receita	Perda financeira superior a 2 000 000 € devido a interrupções de serviços clínicos e cancelamento de consultas.	Perda entre 500 000 € e 2 000 000 € com perturbações temporárias.	Perda inferior a 500 000 € (impacto mínimo e recuperável).
Custo Único Financeiro	Custo superior a 100 000 € (pagamento de resgate, multas RGPD, substituição total de equipamentos).	Custo entre 10 000 € e 100 000 € (auditorias, reforço de segurança).	Custo inferior a 10 000 € (reparações pontuais).
Critérios de Medição de Risco – Produtividade			
Interrupção de Serviços Clínicos	Interrupção superior a 72 horas , com impacto direto nas operações hospitalares, reagendamentos massivos e sobrecarga de equipas.	Interrupção entre 8 e 72 horas , afetando serviços administrativos e consultas não urgentes.	Interrupção inferior a 8 horas , com impacto mínimo na rotina hospitalar.
Critérios de Medição de Risco – Segurança e saúde			
Segurança dos Pacientes	Risco direto à vida ou integridade física (ex.: atraso em diagnósticos, falha em cirurgias devido a indisponibilidade de dados).	Impacto moderado , com atrasos clínicos e necessidade de intervenção manual sem risco vital imediato.	Impacto mínimo, facilmente contornável com processos manuais ou backups físicos.

Prioritização das Áreas de Impacto	
Prioridade	Áreas de Impacto
4	Finanças
3	Produtividade
5	Segurança e saúde

Legenda – Prioritização das Áreas de Impacto:

A escala de prioridade varia de **1 (menor impacto)** a **5 (maior impacto)**.

Step 2 - Desenvolver Perfil do Ativo de Informação

Perfil do Ativo de informação crítico		
Ativo crítico	Motivo de escolha	Descrição
Base de dados dos pacientes	Este ativo contém informação sensível acerca dos pacientes, que é essencial para prestação de cuidados de saúde, diagnósticos e tratamentos, bem como para processos administrativos e financeiros. Qualquer comprometimento deste ativo pode causar falhas nos serviços clínicos e nas operações hospitalares.	Este ativo contém dados pessoais do paciente (nome, idade, contactos), historial médico (diagnósticos, resultados de exames, tratamentos) e informação de faturação. Trata-se de informação altamente sensível e essencial para o funcionamento da organização.
Proprietário do ativo Chief Information Officer (CIO)		
Requisitos de segurança		
Confidencialidade	Apenas funcionários autorizados podem aceder à informação. Os profissionais clínicos apenas podem aceder aos dados pessoais e clínicos dos pacientes. Os funcionários administrativos apenas podem aceder aos dados pessoais e à informação de faturação dos pacientes. Entidades externas também podem aceder a certos dados, desde que formalmente autorizadas.	
Integridade	Apenas funcionários autorizados podem modificar a informação. Os profissionais clínicos só podem alterar informação clínica dos pacientes e os funcionários administrativos só podem alterar informação relativa à faturação. Todas as alterações devem ser registadas. Qualquer alteração indevida pode comprometer decisões médicas e administrativas.	
Disponibilidade	Este ativo deve estar disponível 24 horas, 7 dias por semana, de modo a suportar as operações dos vários hospitais espalhados pelo mundo. Interrupções no serviço podem afetar vários processos, principalmente procedimentos médicos. Interrupções prolongadas podem afetar gravemente o tratamento e o atendimento dos pacientes.	
Regulatórios	Como o ativo contém informação clínica sensível acerca dos pacientes, o tratamento dos dados deve cumprir o RGPD, HIPAA e a legislação local. O não cumprimento pode resultar em sanções legais.	
Requisito de segurança mais importante	Integridade	

Step 3 - Identificar Containers de Ativos de Informação

Mapa de Riscos dos Ativos de Informação – Técnico	
Interno	
Proprietário	Descrição do Container
Equipa médica	A utilização direta dos dados dos pacientes é estritamente reservada para os contextos de diagnóstico, tratamento, monitorização e decisão clínica.
Externo	
Fornecedor de Serviços Cloud	Armazenamento externo da base de dados dos pacientes para recuperação em caso de desastre.
Mapa de Riscos dos Ativos de Informação – Físico	
Interno	
Proprietário	Descrição do Container
Equipa de TI	Servidores físicos internos, onde se encontram os dados dos pacientes, situados no Datacenter do hospital.
Externo	
Fornecedor externo	Os Backups físicos da base de dados são armazenadas em instalações externas.
Mapa de Riscos dos Ativos de Informação – Pessoas	
Interno	
Departamento	Responsabilidade
Serviços Clínicos	Profissionais de saúde com acesso aos registos clínicos dos pacientes
Serviços Administrativos	Equipa Administrativa que acede a dados pessoais e de faturação
Sistemas de Informação	Equipa de TI tem o acesso à base de dados

Externo	
Fornecedor de serviços cloud	O fornecedor de serviços em nuvem fornece uma infraestrutura de armazenamento de backups para a organização, mantendo um acesso indireto (ou potencial) a todos os dados armazenados.

Step 4 - Identificar Áreas de Preocupação

Risco do Ativo de Informação				
Risco do Ativo de Informação	Ameaças	Ativo de Informação	Base de dados dos pacientes	
		Área Crítica	Gestão dos registos clínicos e administrativos dos pacientes abrange a recolha, o armazenamento, a atualização e a partilha de informação necessária para o diagnóstico, tratamento, faturação e marcações.	
		(1) Ator Quem exploraria a vulnerabilidade?	Trata-se Hacker cujo objetivo é visualizar os dados dos pacientes e administrativos.	
		(2) Meios Como é que o ator o faria? O que faria?	A prática de Phishing a funcionários ou a exploração de vulnerabilidades de servidores.	
		(3) Motivo Qual é a razão do ator para o fazer?	O furto de dados é praticado com o intuito de os vender ou de solicitar um pagamento à empresa para a sua devolução.	
		(4) Consequência Qual seria o efeito resultante sobre o ativo de informação?	Divulgação, Destruição e Interrupção do acesso à informação.	
		(5) Requisitos de Segurança Como seriam violados os requisitos de segurança do ativo de informação?	Confidencialidade e Disponibilidade comprometidas.	
		(6) Probabilidade Qual é a probabilidade de este cenário de ameaça ocorrer?	Alta	
	(7) Consequências Quais são as consequências para a organização ou para o proprietário do ativo de informação, resultantes do impacto e da violação dos requisitos de segurança?	(8) Severidade Quão graves são estas consequências para a organização ou para o proprietário do ativo, por área de impacto?		
	A interrupção de serviços clínicos, os atrasos em diagnósticos e tratamentos, a perda de confiança, as multas aplicadas ao Regulamento Geral sobre a Proteção de Dados e os elevados custos de recuperação são as consequências mais graves que se podem verificar.		Área de Impacto	Valor
		Finanças	Alto	12
		Produtividade	Alto	9
		Segurança e saúde	Alto	15

(9) Mitigação do Risco

Com base na pontuação total deste risco, que ação será tomada?

Mitigar — o risco é considerado grave, pelo que não deverá ser aceite nem adiado.

Para os riscos que decidires mitigar, procede do seguinte modo:

Em que contentor aplicarás os controlos?

Que controlos administrativos, técnicos e físicos aplicarás neste contentor? Que risco residual seria ainda aceite pela organização?

Servidores da Base de Dados e Rede Interna Hospitalar

- É imperativo implementar políticas de segurança, formação contra Phishing e auditorias RGD.

Servidores da Base de Dados e Rede Interna Hospitalar

- Aplicar backups diários offline, MFA, atualizações, EDR e segmentação de rede.

Servidores da Base de Dados e Rede Interna Hospitalar

- Risco residual: Erro Humano

Step 5 - Identificar Cenários de Ameaça

Threat Scenario Questionnaire 1 - Technical Containers	
Cenário 1	
Divulgado a pessoas não autorizadas?	Sim (acidentalmente/intencionalmente)
Modificado de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Interrompido de forma a não poder ser acedido para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Destruído permanentemente ou temporariamente perdido, de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Cenário 2	
Divulgado a pessoas não autorizadas?	Sim (acidentalmente/intencionalmente)
Modificado de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Interrompido de forma a não poder ser acedido para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Destruído permanentemente ou temporariamente perdido, de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Cenário 3	
Um defeito de software ocorre	Sim (interrupção/modificação/perda)
Ocorre uma falha de sistema (de origem conhecida ou desconhecida)	Sim (interrupção)
Um defeito de hardware ocorre	Sim (perda)
Código malicioso (vírus, worm, trojan, backdoor) é executado	Sim (divulgação/interrupção /modificação/destruição)
A alimentação elétrica dos containers técnicos é interrompida	Sim (interrupção)
Problemas nas telecomunicações ocorrem	Sim (interrupção)
Problemas com sistemas de terceiros	Sim (interrupção/perda)

Desastres naturais ou provocados (inundação, incêndio, explosão, furacão, tornado, etc.)	Sim (perda)
Threat Scenario Questionnaire 2 - Physical Containers	
Cenário 1	
Divulgado a pessoas não autorizadas?	Sim (acidentalmente/intencionalmente)
Modificado de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Interrompido de forma a não poder ser acedido para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Destruído permanentemente ou temporariamente perdido, de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Cenário 2	
Divulgado a pessoas não autorizadas?	Sim (acidentalmente/intencionalmente)
Modificado de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Interrompido de forma a não poder ser acedido para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Destruído permanentemente ou temporariamente perdido, de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente/intencionalmente)
Cenário 3	
Problemas com terceiros	Sim (interrupção/perda)
Desastres naturais ou provocados (inundação, incêndio, explosão, etc.)	Sim (perda)
Threat Scenario Questionnaire 3 – People	
Cenário 1	
Divulgado a pessoas não autorizadas?	Sim (acidentalmente/intencionalmente)
Modificado de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente)
Interrompido de forma a não poder ser acedido para os propósitos pretendidos?	Sim (acidentalmente)

Destruído permanentemente ou temporariamente perdido, de forma a não poder ser usado para os propósitos pretendidos?	Sim (acidentalmente)
Cenário 2	
Divulgar a informação a pessoas não autorizadas?	Sim (intencionalmente)